Context Matters: Repository-Aware Security Analysis of the Agent Skill Ecosystem

Florian Holzbauer, David Schmidt, Gabriel Gegenhuber, Sebastian Schrittwieser and Johanna Ullrich

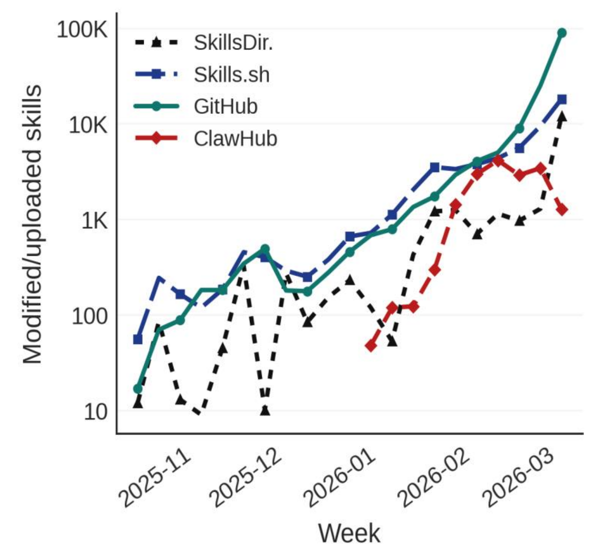
API

Code & Data

CAIS 2026
Agent Skills Workshop

Introduction

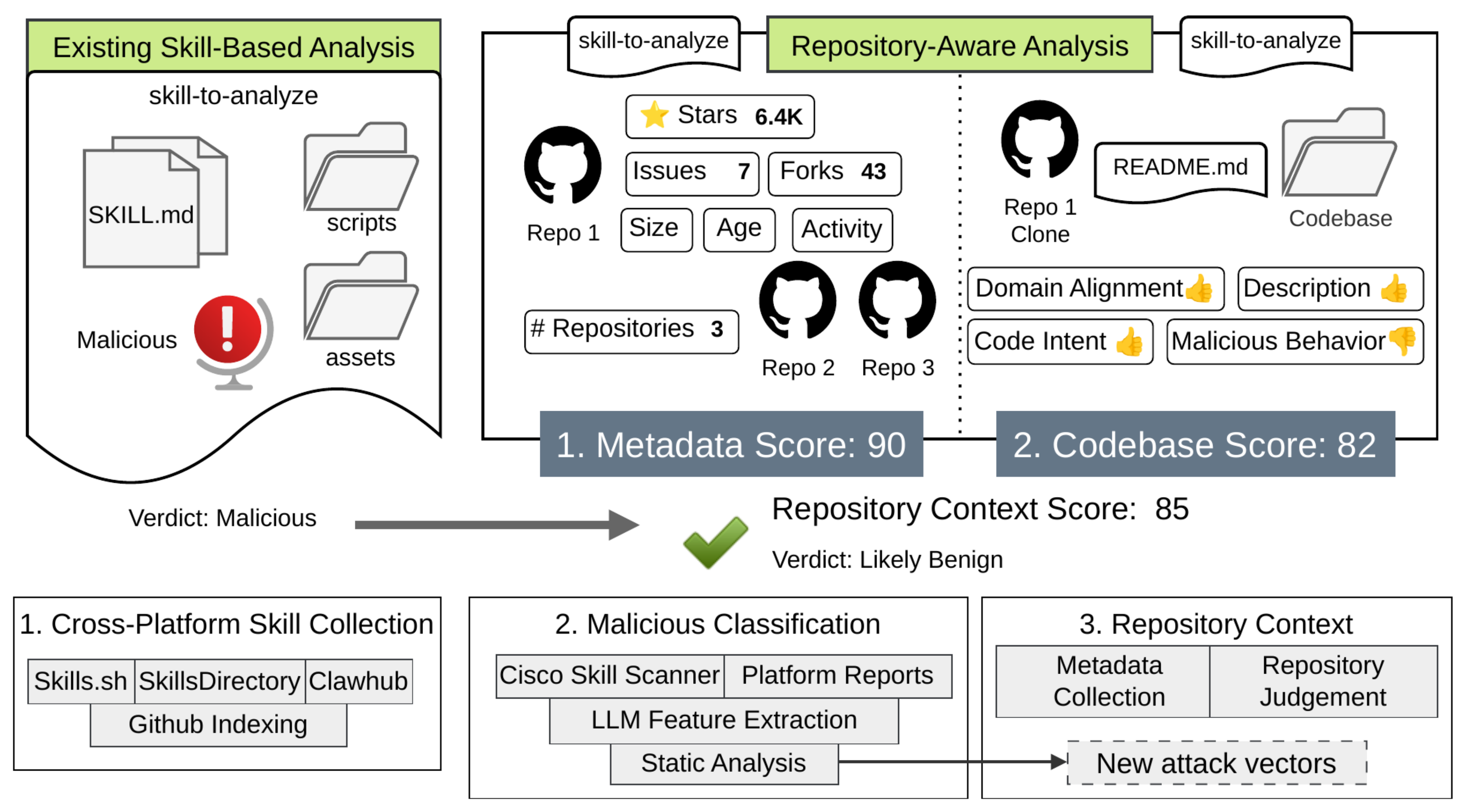
- Increasing demand in sharing **reusable** agent skills.
- Skills are distributed through marketplaces similar to app stores.
- Existing scanners flag **up to 46.8%** of skills as malicious.
- Key problem:
  - Are these really malicious?
  - Or are scanners producing many false positives?



Research Questions

RQ1: What skills are **shared on marketplaces,** and which new **attack vectors** emerge from the skill ecosystem?
RQ2: How do marketplaces and **scanners** classify skills as malicious?
RQ3: Can **repository context** improve existing security classifications of skills?

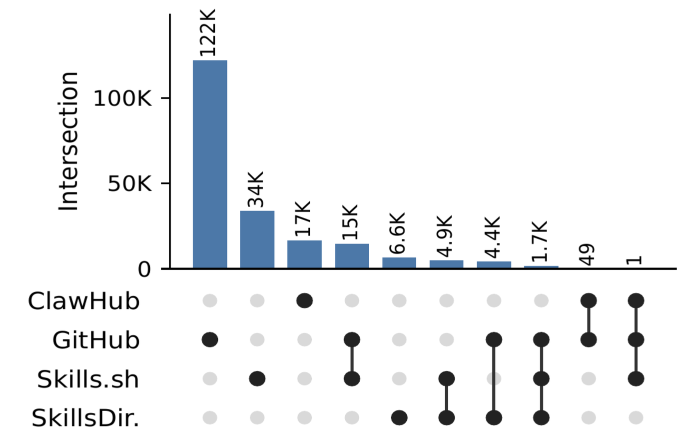
Methodology



RQ1: Cross-Plattform Skills

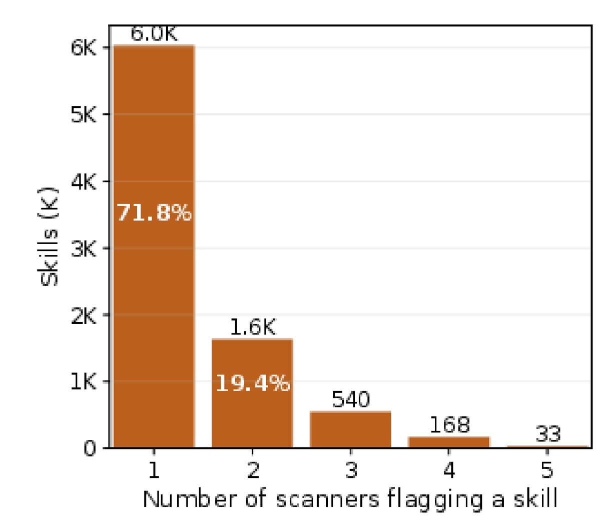
- **Dataset:** 238,180 unique skills statically analyzed.
- **Skill Content:** 44.1% of ClawHub skills contain scripts vs. 11.8-15.7% elsewhere; mostly Python3 and shell scripts.
- **Provisioning:** ClawHub.ai directly; others via GitHub
- **Repository Context:** available for 93% of collected skills.
- **Availability Issues:** stale repo pointers from private repos, deleted users, or deleted repositories.
- **Attack Vector:** takeover of 1K+ install skills via re-registration of deleted GitHub users.
- **Scanner Limitations:** embedded secrets/API tokens often missed, 12 active tokens found.

Skill Metric	ClawHub	SkillsDir.	Skills.sh	GitHub
Indexed	16,755	32,896	79,735	142,824
Retrieved	16,755	17,611	125,928	136,095
Added	16,755	17,611	112,231	91,583
Owners	n/a	709	7,950	14,197
Repositories	n/a	766	9,431	16,413
#Total 238,180 (distinct analyzed skills)				



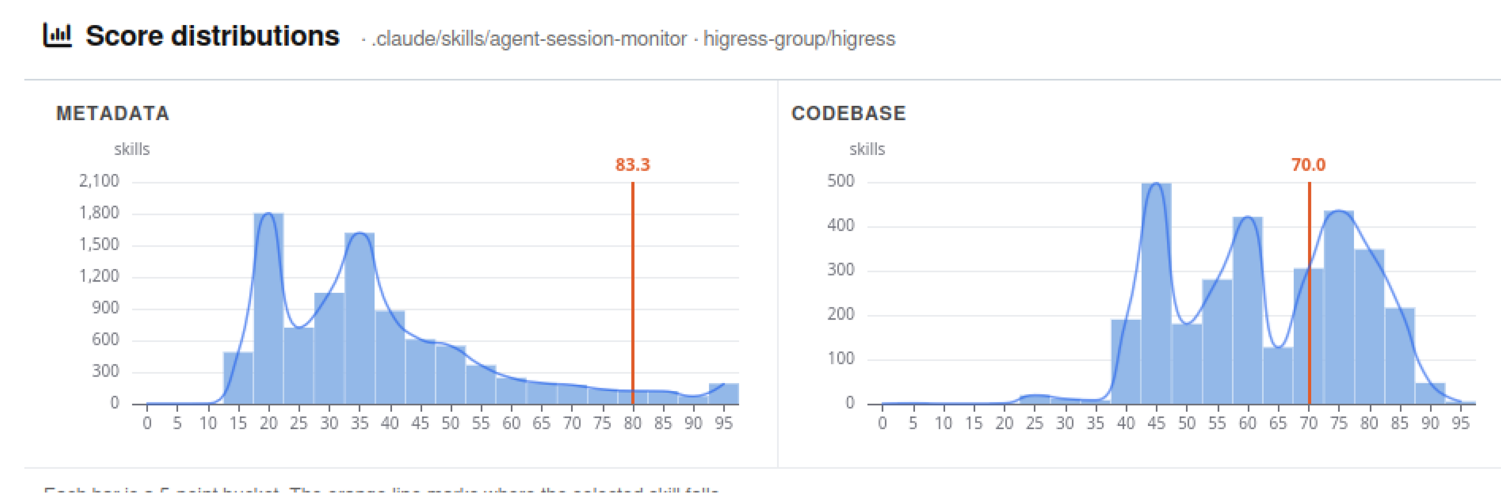
RQ2: Malicious Classification

- **Effect of moderation:** 6% flagged skills on SkillDirectory vs. 23% on Skills.sh and 46.8% on Clahwub.
- **Effect of scanner:** Marketplaces often rely on a set of scanners. Flagging-rates range from 3.8% with Snyk to 42% with OpenClaw scanner.
- **Higher rates at repository level:** More than half of tested repositories with >1000 Stars include at least one flagged skill.
- **Scanner consensus limited:** only 33 out of 8,402 skills (0.4%) are flagged by all five scanners. Skill subset for which reports of all five scanners exist and at least one flags the skill.



RQ3: Repository Context

- **Context Availability: 94%** of repositories contain a README, **66%** contain code, and **62%** contain both.
- **Metadata Score:** Metadata helps distinguish mature projects from immature ones: **43%** of new skill repositories have zero stars, and **73%** are only 1 month to 1 year old. SkillsDirectory scores higher; Skills.sh and GitHub Archive score lower.
- **Codebase Score:** Most flagged skills align with their repository context: **72%** show at least moderate domain alignment, while only **2%** show repository-level maliciousness signs.
- **Context Score Interpretation:** Repository context helps reassess scanner alerts. In the API implementation, for example `alibaba/higress/agent-session-monitor` reaches a context score of **74** despite being scanner-flagged, shifting the interpretation from malicious toward likely benign.



Conclusion

- **Skill marketplaces inherit GitHub supply chain risks:** Lightweight publication also brings broken links, hijackable skills and weak provenance.
- **Skill scanners overstate ecosystem maliciousness:** Low scanner agreement and widely varying detection rates show that isolated flags can exaggerate risk.
- **Repository context makes scanning more useful:** Checking the surrounding code and documentation helps separate suspicious behavior from legitimate functionality.
- **Limitation:** Repository-aware scanning improves interpretation, but cannot establish ground truth.